

Session 6

Session By: Wafaa Atef

Slides By: Omnia , Yomna

Table of contents </>

- 1 - Intro to Authentication & Authorization
- 2 - Authentication concept
- 3 - Token & cookies
- 4 - Sign up/in flow
- 5 - Authorization concept
- 6 - Admin Panel
- 7 - Kahoot !

Introduction to Authentication & Authorization

Story!

H

2

Authentication

Authentication

Authentication

Who are you?

- ★ Authentication = verifying identity
- ★ Happens before authorization

Authentication in Real Life

- ❖ Showing your ID card
- ❖ Entering a password to unlock your phone
- ❖ Using fingerprint / Face ID

Authentication in Applications

Authentication



Login

Question!

Http is stateless or not?



Http is stateless!

- which means each request is independent and the server does not remember previous requests by default

And There is a Problem

- ❖ Login is done once
- ❖ so , When a user logs in successfully, the backend needs a way to remember them in future requests.
- ❖ That 'memory' is done using either sessions or tokens.

Session-Based Authentication vs Token-Based Authentication

Session-Based Auth

- After login, the server creates a **session**
- The session data is stored on the **server (memory or database)**
- A **session ID** is generated
- The session ID is sent to the client as a cookie



cookies

- Cookies are **small pieces of data** created by the backend and stored in the **user's browser**.
- They are automatically sent with **every request** to the backend

Why Are cookies Important in Backend?

- Because HTTP is stateless, the backend uses cookies to **maintain user state** across multiple requests.
- Cookies allow the server to recognize the same user without requiring repeated authentication

Token-Based Auth

After login, the server generates a token

The token contains user data

The token is sent to the client

The client stores it (usually in a cookie)

Token

- A token is a **secure string** used to represent an authenticated user.
- It is generated by the server after successful authentication and **sent to the client** to prove the **user's identity** in future requests

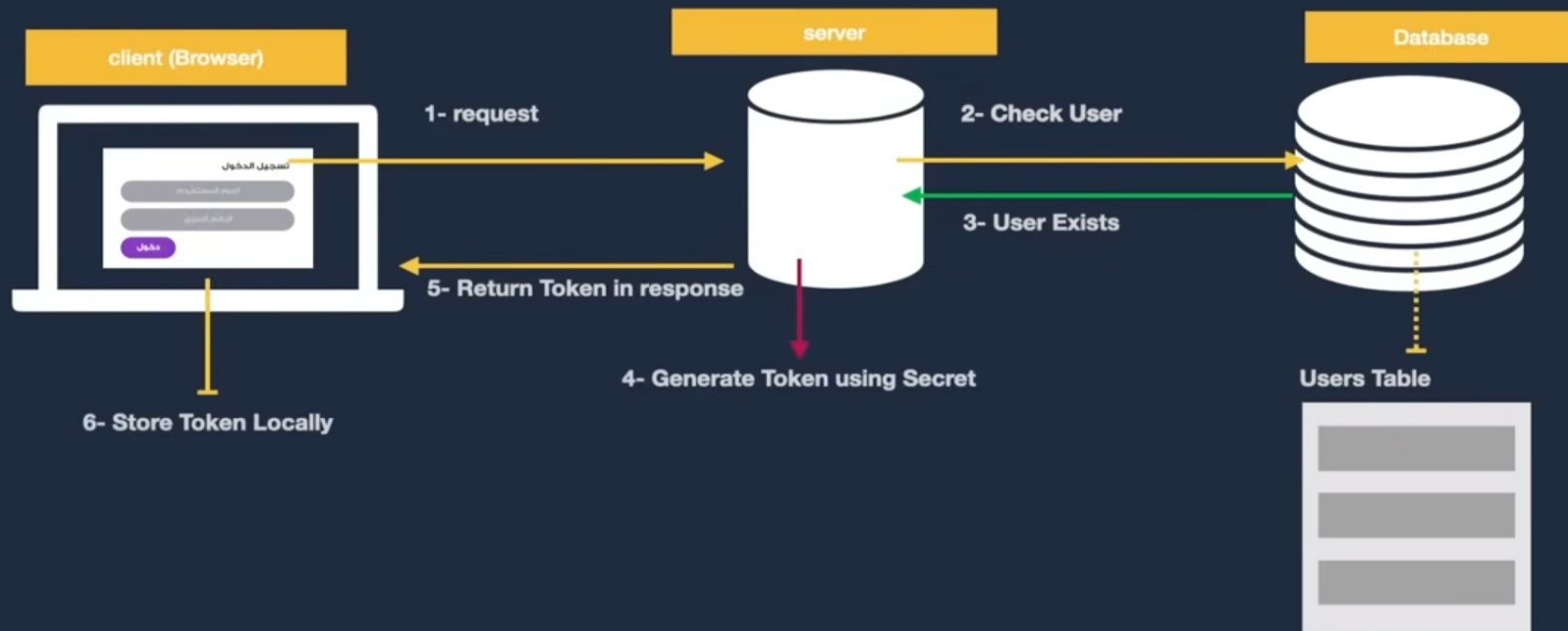
Why Tokens Are Important in Backend?

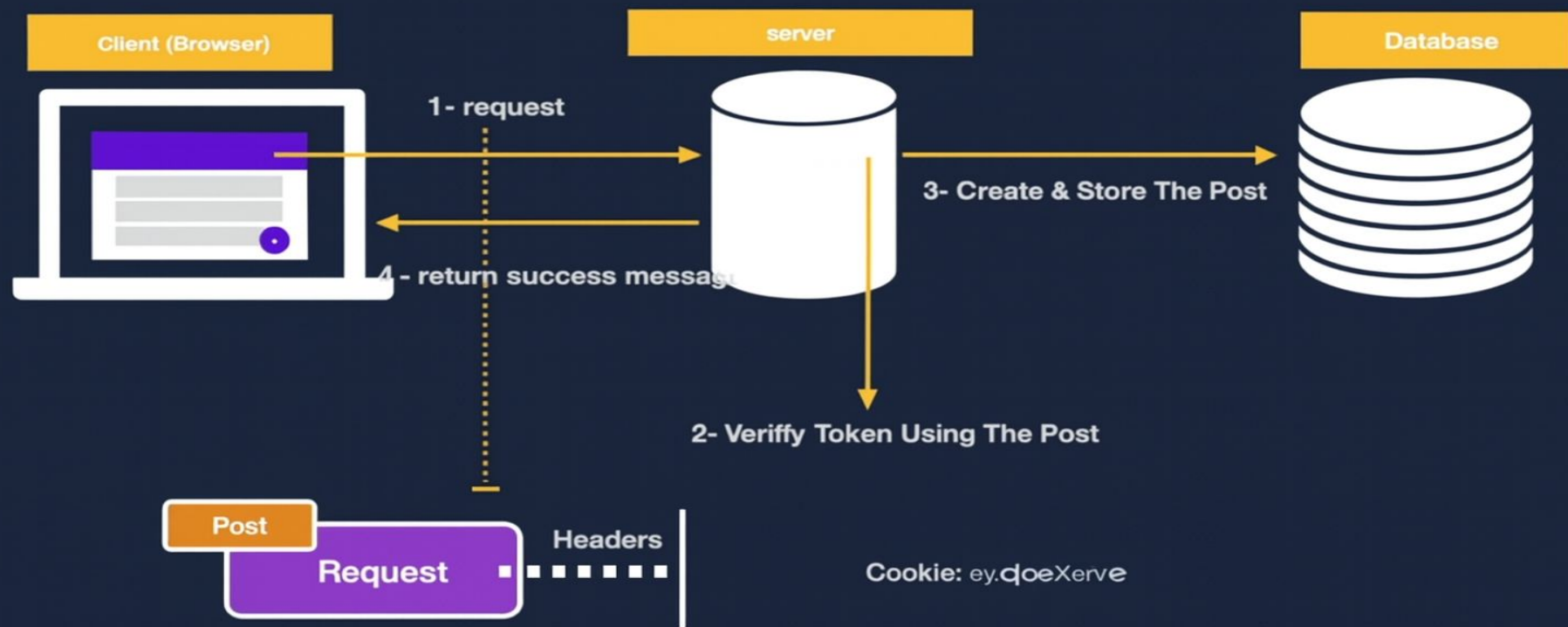
- Tokens enable **stateless authentication**, meaning the server does not need to store session data.
- They allow the backend to **identify the user** on every request without asking for credentials again.
- Tokens help maintain **secure communication** between the frontend and backend.

Role of Tokens in Authentication & Authorization

- In **Authentication**, tokens confirm that the user has successfully logged in.
- In **Authorization**, tokens carry information as “user ID” or “role” that helps determine what the user is allowed to access.
- Tokens are validated by the backend on **each request** to ensure the request is legitimate

Break . . .





JSON Web Token (JWT)

- A compact, secure token used for authentication
- Sent from backend → client after successful login
- Used in every request to identify the user
- JWT consists of 3 parts: (jwt.io)
[Header.Payload.Signature](#)
 - ◆ Header → token type & algorithm
 - ◆ Payload → user data (id, role, email)
 - ◆ Signature → ensures token is not tampered with

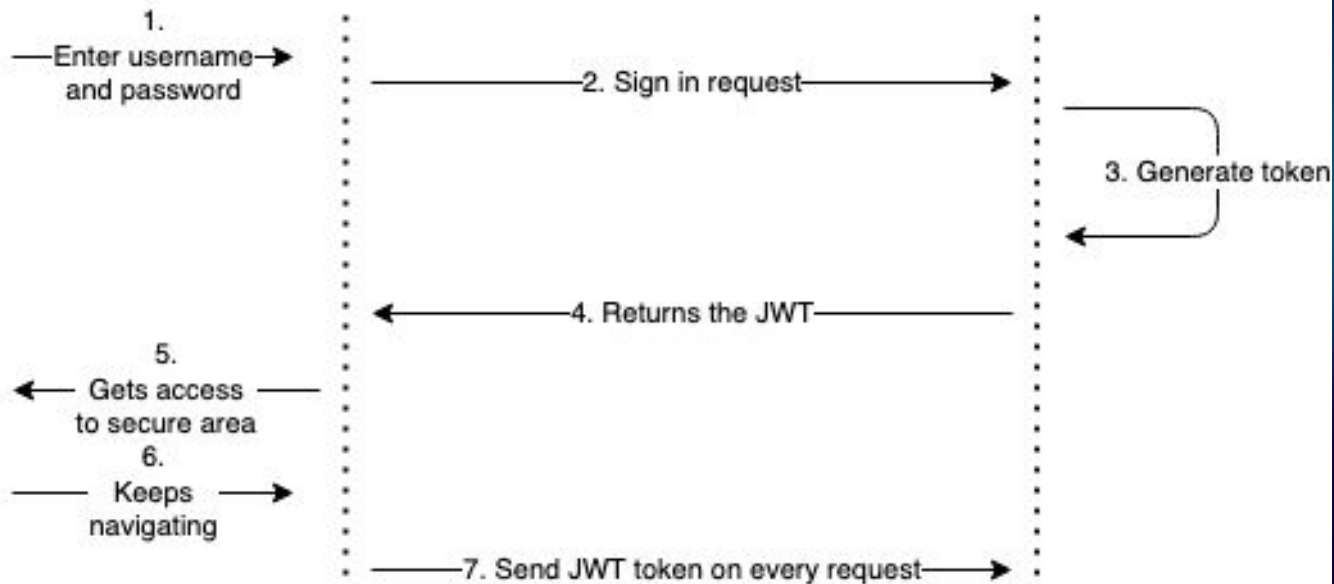
Sign up/in flow





Client app

API





Authorization concept

Authorization

What do you do?

- ★ Authorization = verifying **role**
- ★ Is the process of **determining what actions an authenticated user is allowed to perform**

Authorization in Real Life

- ❖ Being allowed to delete a post as an admin
- ❖ Accessing your bank account features based on your role
- ❖ Viewing restricted content after logging in
- ❖ Opening specific apps or settings on your phone based on permissions

Admin Panel Demo !





Kahoot !

Thanks!

Do you have any questions?